

מודול 15 — הנדסה חברתית ופישינג — תרגילים ופתרונות

חומר לימוד

2 יחידות

תוכן העניינים

1.  תרגילים — מודול 15: הנדסה חברתית ופישנינג
2.  פתרונות מלאים — מודול 15: הנדסה חברתית ופישנינג

תרגילים — מודול 15: הנדסה חברתית ופשינג

⚠ **אתיקה קריטית!** תרגל רק על עצמך, על מעבדה שלך, או בהרשאה מפורשת בכתב. פשינג של אדם/ארגון ללא רשות = עבירה פלילית ופגיעה באנשים אמיתיים. אל תשלח מיילים מזויפים לאיש ללא אישור. פתרונות ב- `solutions.md`.

מקרא רמות: קל • בינוני • מתקדם • אתגר

חלק א' — עקרונות (●)

15.1 — רשום את ששת עקרונות ההשפעה של צ'לדיני, ולכל אחד תן דוגמה לניצול בהתקפת פשינג.

15.2 — הסבר את ההבדל בין Whaling ו-Phishing, Spear Phishing. איזה הכי יעיל בבדיקה אמיתית ולמה?

15.3 — נתח מייל פשינג אמיתי (מתיקית הספאם שלך). זהה 4 סימני אזהרה.

חלק ב' — OSINT ותכנון (●)

15.4 — בצע OSINT על עצמך (או על חברה בהסכמה): כמה מידע ציבורי תוכל למצוא (מיילים, תפקידים, טכנולוגיות)? השתמש ב-theHarvester ו-LinkedIn.

15.5 — נסח מבנה מיילים של ארגון פיקטיבי (`firstname.lastname@`) והסבר איך OSINT עוזר לנחש כתובות מייל.

15.6 — כתוב טקסט של מייל ספיר-פשינג משכנע (תרחיש: "איפוס סיסמת IT"). אילו עקרונות השפעה שילבת?

חלק ג' — קמפיין מבוקר (●)

15.7 — התקן את GoPhish והרץ אותו. צור Landing Page ו-Email Template (שבט של דף התחברות) בסביבת מעבדה שלך בלבד.

15.8 — הרץ קמפיין ניסיוני על עצמך (כתובת שלך). בדוק שהמדדים (פתיחה/לחיצה) נרשמים בדוח.

15.9 — הסבר כיצד evilginx עוקף MFA. למה זה מדגים שגם 2FA אינו הגנה מושלמת?

● אתגר מסכם — “תרגיל מודעות פשינג (מבוקר)”

תכנן קמפיין הדרכת מודעות מלא על ארגון פיקטיבי (או מעבדה בהסכמה):

1. OSINT — אסוף “מטרות” (רשימה פיקטיבית) ומבנה מיילים.
2. תסריט (Pretext) — בחר תרחיש אמין (IT / HR / משלוח).
3. בנה ב-GoPhish: Template + Landing Page + Group.
4. הרץ על כתובות שלך/הסכמה, ואסוף מדדים.
5. תעד דוח: אחוזי פתיחה/לחיצה/מסירה, בלי שמות, + המלצות (הדרכות, MFA, סינון). כתוב את קטע האתיקה — כיצד תציג את התוצאות מבלי לבייש עובדים.

📌 דוח מודעות פשינג הוא תוצר מרכזי בבדיקות PNPT. הדגש בו את הצד המחנך — זו נקודת המכירה ללקוח.

✅ רשימת בקרה — לפני מעבר למודול 16

- ☐ אני מכיר את עקרונות ההשפעה ומזהה אותם בהתקפות
- ☐ אני מבחין בין Phishing/Spear/Whaling/Vishing/Pretexting
- ☐ אני מבצע OSINT לאיסוף מטרות (theHarvester, LinkedIn)
- ☐ אני מזהה סימני מייל פשינג
- ☐ אני בונה קמפיין מבוקר ב-GoPhish ומודד תוצאות
- ☐ אני מבין evilginx ועקיפת MFA
- ☐ אני יודע לנהל את הבדיקה אתית (Scope, דיווח ללא שיימינג)

פתרונות מלאים: [solutions.md](#)

✅ פתרונות מלאים — מודול 15: הנדסה חברתית ופשינג

נסה לבד ב- [missions.md](#) קודם. רק על עצמך / מעבדה / בהרשאה בכתב.

חלק א' — עקרונות

15.1 Reciprocity — “צירפתי לך קופון, אשר את הפרטים”. - **Commitment** — סקר קצר → בהמשך בקשת סיסמה. - **Social Proof** — “כל המחלקה כבר עדכנה את הפרטים”. - **Authority** — “מדבר מנהל ה-IT / הבנק”. - **Liking** — בניית קרבה בציאט לפני הבקשה. - **Scarcity** — “הקישור בתוקף ל-24 שעות בלבד”.

15.2 Phishing = המוני וגנרי; **Spear Phishing** = ממוקד ומותאם אישית; **Whaling** = ספיר-פישנג לבכיר. **Spear Phishing הכי יעיל** — התאמה אישית (שם, תפקיד, פרויקט) מעלה דרמטית את שיעור הלחיצה.

15.3 — סימנים: דומיין שולח שגוי, דחיפות/איום, שגיאות כתיב, לינק שה-URL שלו שונה מהטקסט, בקשת פרטי התחברות.

חלק ב' — OSINT ותכנון

15.4

```
theHarvester -d company.com -b all
# + LinkedIn (עובדים/תפקידים), GitHub, Google Dorking
```

לרוב מפתיע כמה מידע ציבורי קיים: מיילים, מבנה ארגוני, טכנולוגיות.

15.5 — מזהים דפוס מ-OSINT (מייל אחד שדלף) → `firstname.lastname@` → מרכיבים כתובות לכל העובדים שמצאת ב-LinkedIn.

15.6 — דוגמה: “מאת: IT Support. עקב שדרוג אבטחה, אפס את סיסמתך תוך 24 שעות בקישור המצורף אחרת חשבונך יושבת.” — משלב **Scarcity/Urgency** (IT) + **Authority** (24 שעות) + **Fear** (השבתה).

חלק ג' — קמפיין מבוקר

15.7

```
./gophish https://localhost:3333 -ממשק ב #
# Landing Pages → Import Site (שבט) → Capture Credentials
# Email Templates → HTML עם {{.URL}}
```

15.8 — צור Group עם המייל שלך בלבד, הרץ Campaign, ובדוק בלשונית / Results: Email Opened / Submitted Data Clicked Link / נרשמים.

15.9 — evilginx יושב כ-reverse proxy בין הקורבן לאתר האמיתי; הקורבן מתחבר (כולל MFA) דרכו, ו-evilginx גונב את ה-session cookie אחרי האימות. עם ה-cookie התוקף נכנס בלי לעבור MFA שוב → מוכיח ש-2FA לא עוצר פשינג מתקדם (אך כן מקשה).

אתגר מסכם — מבנה דוח מודעות

<דוח סימולציית פשינג – >ארגון

היקף

.בהרשאת ההנהלה, "IT עובדים, מייל" איפוס סיסמת 120

תוצאות (ללא שמות)

- 68% פתחו את המייל:
- 31% לחצו על הלינק:
- 12% הזינו פרטים:

ניתוח

.שילוב סמכות+דחיפות היה יעיל; מחלקת המכירות הכי חשופה

המלצות

- הדרכת מודעות + סימולציות רבעוניות.
- בכל המערכות MFA אכיפת
- סינון אנטי-פשינג + SPF/DKIM/DMARC
- כפתור "דווח על פשינג" בקליינט המייל.

אתיקה

.התוצאות מוצגות כאחוזים בלבד – ללא זיהוי עובדים.
המטרה: חינוך ושיפור, לא ענישה

עברת? יש לך דוח מודעות פשינג אתי ומקצועי. המשך למודול 16.